



Red Team week-4 Lab Report

Tester: Biswojeet Barik

OSINT and Recon Lab

Executive Summary

This simulated campaign emulated a multi-phase adversary targeting a controlled lab environment to evaluate defensive telemetry and response. Activities included reconnaissance of cloud assets, phishing-based credential harvesting, establishing C2 sessions, payload obfuscation to test endpoint detection, and simulated exfiltration from mock S3 buckets. Blue team tooling (Wazuh) produced alerts for privileged API activity, anomalous access patterns, and suspicious process creations; however, several telemetry gaps were identified, including incomplete logging of PowerShell execution and insufficient alerting on anomalous role assumption. Key findings: a publicly readable S3 bucket allowed mock data exposure, an over-privileged IAM role permitted escalation, and an obfuscated Meterpreter-like payload bypassed the lab AV. Recommendations prioritize rapid remediation: enforce least privilege on cloud roles, enable S3 block-public-access and object-level logging, deploy endpoint telemetry for script-based activity (Constrained Language Mode, PowerShell logging), enforce MFA for privileged users, and tune detection rules to capture chained behaviors (phishing → credential use → role escalation → data access). Remediation and repeat testing are recommended to validate fixes and measure detection maturity.

Advanced C2 Lab –

Objective: Establish and manage C2 infrastructure using enterprise tools

- **Tools:** Cobalt Strike, PoshC2, Metasploit
- **Results:** Successfully configured HTTPS Beacon, established session with Windows VM (192.168.138.125)

Logs:

Session ID	Target IP	Payload Type	Notes
SID001	192.168.138.25	PowerShell	Beacon established



50-word summary (C2 setup): Configured and validated an HTTPS-based command-and-control beacon in the lab. A Windows VM phone-home created a stable session (SID001) using a stageless PowerShell payload. Session management proved functional; endpoint telemetry lacked script-block logging and required improved detection for beacon callbacks and staged execution.

Cloud Attack Lab

Objective: Conduct cloud reconnaissance, privilege escalation, and data exfiltration

- **Tools:** Pacu, awscli, CloudGoat
- **Results:** Identified vulnerable S3 bucket, escalated privileges via IAM misconfiguration
- **Log:**

Asset ID	Service	Misconfiguration	Notes
AID001	S3	Public read access	Vulnerable bucket

50-word summary (Cloud privilege escalation): Cloud reconnaissance identified an S3 bucket with public read access and an over-privileged role. Using lab tools to simulate exploitation, the role's permissions allowed escalation to administrative capabilities. Logs captured anomalous API calls, but alert thresholds were too high—delayed detection increased simulated dwell time.

Exfiltration confirmation: Mock data retrieval from the S3 bucket was logged; object GETs matched the test timeframe and source IPs.

Adversary Emulation

Objective: Emulate APT29 tactics and test detection capabilities

- **Tools:** Caldera, Metasploit, Evilginx2
- **Results:** Successfully simulated phishing and persistence techniques
- **Log:**

Phase	TTP	Tool Used	Notes
Phishing	T1566.001	Evilginx2	Credential harvest



Summary: Simulated APT-style phishing campaign that harvested credentials and established persistence. Wazuh generated alerts for suspicious HTTP activity and an anomalous authentication, but correlation between phishing and subsequent privilege changes was inconsistent. Improving cross-source correlation will reduce detection latency.

Advanced Evasion Techniques

Objective: Develop and test payload obfuscation and network evasion

- **Tools:** msfvenom, Veil, proxychains
- **Results:** Successfully bypassed AV with obfuscated payloads
- **Log:**

Payload ID	Type	AV Detection	Notes
PID001	Meterpreter	Bypassed	Obfuscated payload

Summary: Obfuscated payload encoding evaded lab AV, validating the need for behavior-based detection. Network-level indicators were sparse due to encrypted C2 channels. Recommended improvements include enhanced process monitoring and detection rules for suspicious encoding/packing behaviors in memory.

Network evasion note: C2 traffic routed through anonymizing proxies increased attribution difficulty in lab logs.

Cloud Privilege Abuse

Objective: Simulate privilege abuse in cloud environments

- **Tools:** Pacu, awscli, ScoutSuite
- **Results:** Successfully exploited overprivileged IAM roles
- **Log:**

Attack ID	Service	Misconfiguration	Notes
AID002	IAM	Overprivileged role	Escalated to admin

Summary: An overprivileged IAM role was abused to escalate privileges to admin within the lab environment. The event produced IAM policy-change and AssumeRole



API calls; however, fine-grained CloudTrail analytics were not configured to alert on unusual role assumptions in real time.

Automated Attack Orchestration

Objective: Automate multi-phase attack scenarios

- **Tools:** Caldera, Red Team Automation (RTA)
- **Results:** Successful end-to-end automation of attack chain
- **Log:**

Phase	TTP	Tool Used	Notes
Exploitation	T1190	Caldera	Automated RCE

Summary: Caldera-driven automation executed a chained phishing to exploit scenario, significantly reducing manual steps. Automation highlighted how small telemetry gaps can scale into large campaign impact; detection logic must focus on sequences across identity, endpoint, and cloud telemetry to be effective.

Living-Off-the-Land Techniques

Objective: Execute attacks using native OS tools

- **Tools:** PowerShell, WMI, Mimikatz
- **Results:** Successful fileless execution and credential harvesting
- **Log:**

Attack ID	Tool	Action	Notes
LID001	PowerShell	Fileless execution	Bypassed AV

Summary: Fileless attacks using native PowerShell and WMI successfully bypassed antivirus solutions. Credential harvesting via in-memory techniques demonstrated the effectiveness of living-off-the-land methodologies.



Findings Table

Finding ID	TTP	CVSS Score	Remediation
FID001	Phishing (T1566)	7.5	Enforce MFA; user awareness
FID002	S3 public access	8.0	Block public access; enable logging
FID003	Overprivileged IAM	9.0	Least privilege; role auditing
FID004	Fileless PS exec	7.0	Enable PowerShell logging; EDR
FID005	Obfuscated payload	7.5	Behavior-based detection; EDR

Remediation & Recommendations

- **Identity & Access:** Enforce least privilege, implement just-in-time access apply MFA for all privileged principals, and review IAM policies regularly
- **Cloud Configuration:** Enable S3 Block Public Access, enable object-level logging, lifecycle policies for sensitive data, and use guardrails (SCPs / service control policies) in multi-account environments.
- **Endpoint Telemetry:** Enable PowerShell script block logging, Module logging, AMSI hooks, and centralized EDR with process ancestry visibility.
- **Detection Engineering:** Create detections for chained behaviors (phishing → credential use → role assumption → data access). Lower thresholds for anomalous role assumption and sensitive object GETs.
- **Network & C2:** Monitor egress for irregular TLS fingerprints, unusual certificate use, and long-lived connections to rare endpoints.
- **Operational:** Run tabletop exercises, periodic red-team engagements, and ensure post-remediation validation with repeat tests.

Non-Technical Briefing for Executives:

A simulated adversary conducted a controlled campaign against our isolated lab to test detection and response. The exercise revealed a public cloud storage bucket and an over-privileged cloud role that could expose data and allow administrative takeover in a real environment. While defensive systems generated alerts, they were not consistently correlated fast enough to prevent data retrieval. We recommend immediate enforcement of least privilege, enabling cloud access logging, mandatory multi-factor authentication for all privileged users, and strengthening endpoint visibility. Implement



menting these steps will considerably reduce the risk and improve our ability to detect and respond to similar threats.